JS

Jahangir Shukurov | GRC Portfolio

PROJECT 2 | ASSESSMENT REPORT

Threat-Informed Risk Assessment

Risk profile, attack scenarios and treatment plan

Client	**Orvanta Payments UAB**
Document ID	**ORV-RISK-003**
Version	**1.0**
Date	**12 February 2027**
Classification	**Confidential (sample)**

> Sample engagement — fictional company, prepared for portfolio purposes.

Document control

Field	Value
Document ID	ORV-RISK-003
Title	Threat-Informed Risk Assessment
Version	1.0
Date	12 February 2027
Author	Jahangir Shukurov
Reviewer	Lukas Jankauskas, Risk Manager
Approver	Ugnė Baltrūnaitė, CEO
Classification	Confidential (sample)

Version history

Version	Date	Author	Change
0.1	5 February 2027	Jahangir Shukurov	Draft for risk owner review
1.0	12 February 2027	Jahangir Shukurov	Issued to the CEO and Management Board

Contents

1 Executive summary....3
2 Scope and method....4
3 Risk profile....4
3.1 From inherent to target....4
3.2 Heat maps....5
3.3 Top 10 risks today....5
4 Attack scenarios....6
4.1 Cloud credential compromise (SCN-A)....6
4.2 Ransomware through phishing (SCN-B)....7
4.3 Insider data exfiltration (SCN-C)....8
5 Risk treatment plan....9
5.1 Accepted risk....10
5.2 What treatment does not fix....10
5.3 Next steps....10
6 Appendix: risk register summary....11

1 Executive summary

Situation. The gap assessment showed where Orvanta falls short of ISO/IEC 27001:2022. This assessment asks what could actually go wrong, how badly and how soon. We assessed 30 risks across 40 assets and 21 threats, using the method approved on 18 December 2026. The position is as of 29 January 2027, after the eight quick wins.

30	26	1	26
Risks assessed	High or Critical today	High after treatment	Treatment actions

Key findings.

- **Most risk is still above appetite.** 26 of 30 risks are High or Critical today. Existing controls and the quick wins keep 12 risks out of Critical, but not within appetite.
- **Two risks are Critical.** Cloud administrator takeover (RSK-01) and intrusion goes undetected (RSK-05). Together they mean an attacker could take over production and not be noticed.
- **Identity is the common thread.** 5 risks trace back to open identity and privileged access gaps, and all three attack scenarios pass through them.
- **Suppliers carry unmeasured risk.** 4 risks depend on vendors nobody has assessed, including the KYC provider and the card processor.
- **The plan works on paper.** 26 actions bring 29 risks within appetite by August 2027. One risk needs formal acceptance.

Risk in business terms. The two Critical risks combine into one outcome: production taken over with nobody noticing. That could cost more than EUR 2M and put the licence at risk. Until treatment lands, a single stolen credential is the most likely way there.

Decisions needed.

#	Decision	Owner	By
1	Approve the risk treatment plan of 26 actions	Ugnė Baltrūnaitė	26 Feb 2027
2	Accept the single-region risk (RSK-16) until 31 December 2027, with conditions	Ugnė Baltrūnaitė	12 Feb 2027
3	Confirm the risk appetite: scores up to 9 without formal acceptance	Management Board	26 Feb 2027
4	Receive a risk report each quarter, starting April 2027	Management Board	26 Feb 2027

2 Scope and method

The assessment covers the full ISMS scope: all products, AWS production, both offices, remote work and suppliers handling Orvanta data. It follows the Risk Management Methodology (ORV-RISK-001), aligned with ISO/IEC 27005:2022 and ISO/IEC 27001:2022 clause 6.1.2.

Evidence basis. Workshops and evidence are simulated for this portfolio sample. Risk owners named here are fictional role-holders from the Company Fact Sheet.

- **Workshops.** Nine sessions with risk owners between 11 and 29 January 2027, using the gap assessment results as the starting point.
- **Two ways in.** Risks were identified from the asset register and from attack scenarios, then merged into one register.
- **Three scores.** Inherent, current with existing controls, and target after treatment. Score is likelihood multiplied by impact, each from 1 to 5.
- **Threat mapping.** Adversarial threats are mapped to MITRE ATT&CK techniques, checked against the public knowledge base.

Level	Score	Required response	Who may accept
Critical	17 to 25	Treat immediately. Acceptance only as a time-limited exception.	Management Board
High	10 to 16	Treatment plan required. Acceptance needs a written record.	CEO
Medium	5 to 9	Within appetite. Monitor and treat where cost is reasonable.	Risk owner
Low	1 to 4	Within appetite. Record and review yearly.	Risk owner

3 Risk profile

3.1 From inherent to target

Without any controls, every risk would be High or Critical. Existing controls and the quick wins bring the average score from 17.4 to 13.6. The treatment plan is designed to reach 5.9.

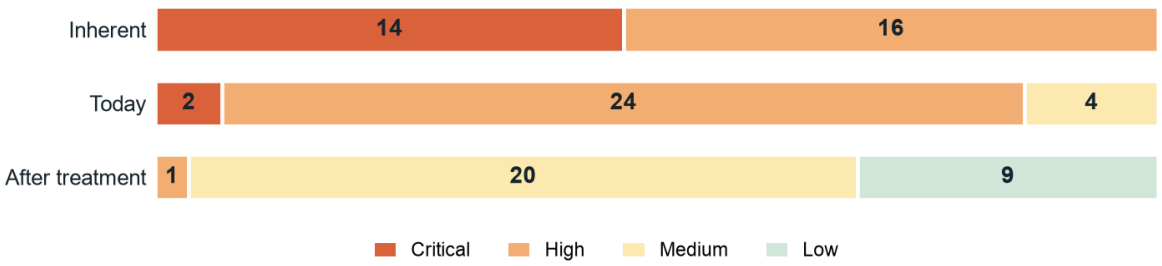


Figure 1: Number of risks at each level: inherent, today and after treatment.

3.2 Heat maps

Each number is a risk ID. Today the risks cluster at high impact with likelihood 3 or 4. Treatment mostly reduces likelihood, because it closes attack paths, and reduces impact where data is masked or backups are isolated.

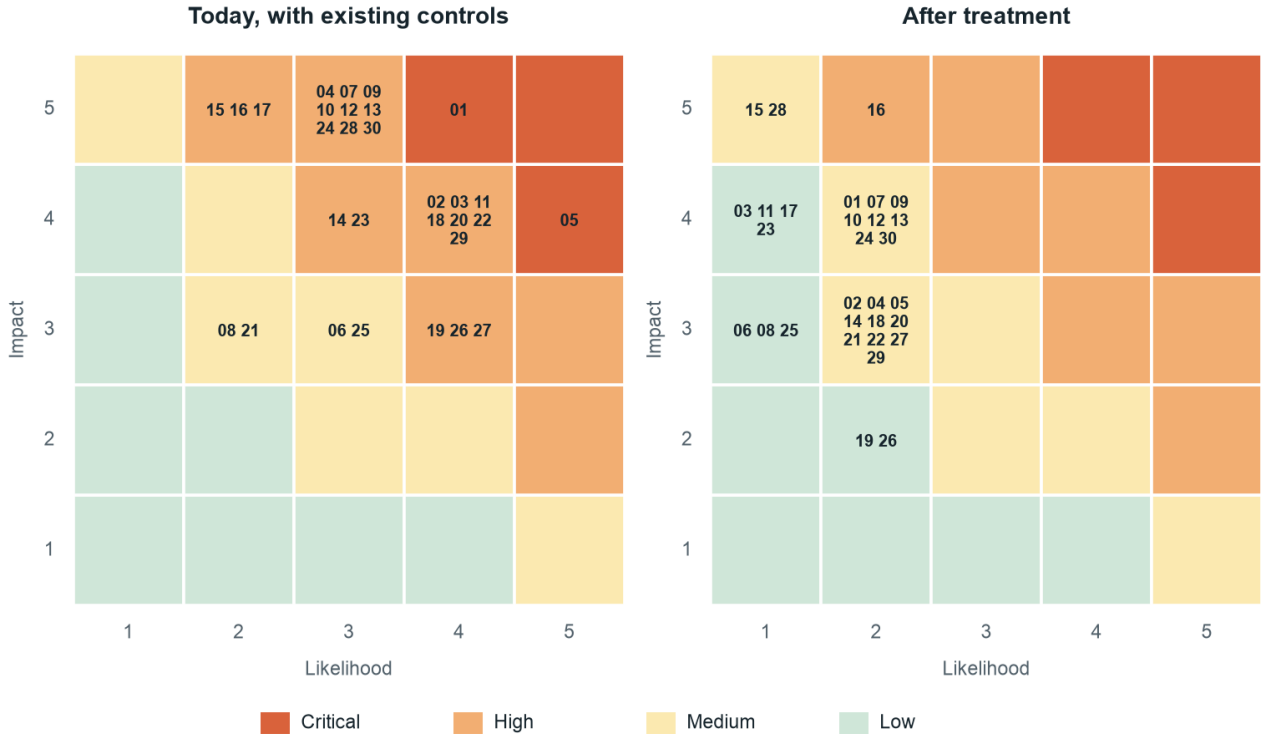


Figure 2: Risk positions today and after treatment. Numbers are risk IDs (01 is RSK-01).

3.3 Top 10 risks today

ID	Risk	Owner	Today	Level	Target
RSK-01	Cloud administrator takeover	Rashad Guliyev	20	Critical	8
RSK-05	Intrusion goes undetected	Nino Beridze	20	Critical	6
RSK-02	Credential phishing of engineers	Nino Beridze	16	High	6
RSK-03	Password attacks on tools outside Okta	Farid Ismayilov	16	High	4
RSK-11	Exploitation of legacy internet-facing services	Rashad Guliyev	16	High	4
RSK-18	Incident mishandled and reporting duties missed	Nino Beridze	16	High	6
RSK-20	Personal data accessed from Baku without transfer safeguards	Karolis Vaitkus	16	High	6
RSK-22	Session theft from an unmanaged device	Farid Ismayilov	16	High	6
RSK-29	DORA ICT risk duties not met	Eglė Norvilaitė	16	High	6
RSK-09	Unreviewed or malicious change reaches production	Tural Mammadli	15	High	8

4 Attack scenarios

Three scenarios test whether controls would hold against a real attack. Each follows the attacker step by step and rates the controls that should prevent, detect or respond. Ratings after treatment are by design, and Project 5 tests them through audit.

4.1 Cloud credential compromise (SCN-A)

An engineer is phished, a live session is stolen from an unmanaged laptop, and stored keys lead to cloud admin rights and customer data.

Threat actor: Financially motivated external attacker | Linked risks: RSK-01, RSK-02, RSK-05, RSK-22, RSK-30



Figure 3: Cloud credential compromise: control coverage at each step, today and after treatment. Cells show Annex A control IDs.

Step	ATT&CK technique	What happens at Orvanta
1	T1566.002 Spearphishing Link	Engineer follows a link to a fake Okta login page
2	T1539 Steal Web Session Cookie	Session token is lifted from an unmanaged laptop, bypassing MFA
3	T1552.001 Credentials In Files	Long-lived AWS keys are found in repositories
4	T1078.004 Cloud Accounts	Shared admin account in the legacy AWS account is used
5	T1580 Cloud Infrastructure Discovery	Accounts, buckets and databases are listed
6	T1136.003 Cloud Account	A new IAM user is created to keep access
7	T1530 Data from Cloud Storage	KYC files are copied from S3

What this shows. Today the path is open at every step, and nothing would raise an alarm before data leaves. After treatment, three independent barriers stand in the way: device trust, short-lived credentials and just-in-time admin rights.

4.2 Ransomware through phishing (SCN-B)

A malicious attachment runs on an unprotected laptop, the attacker enters AWS over the legacy VPN, deletes backups and encrypts production data.

Threat actor: Ransomware affiliate | Linked risks: RSK-02, RSK-03, RSK-04, RSK-11, RSK-17

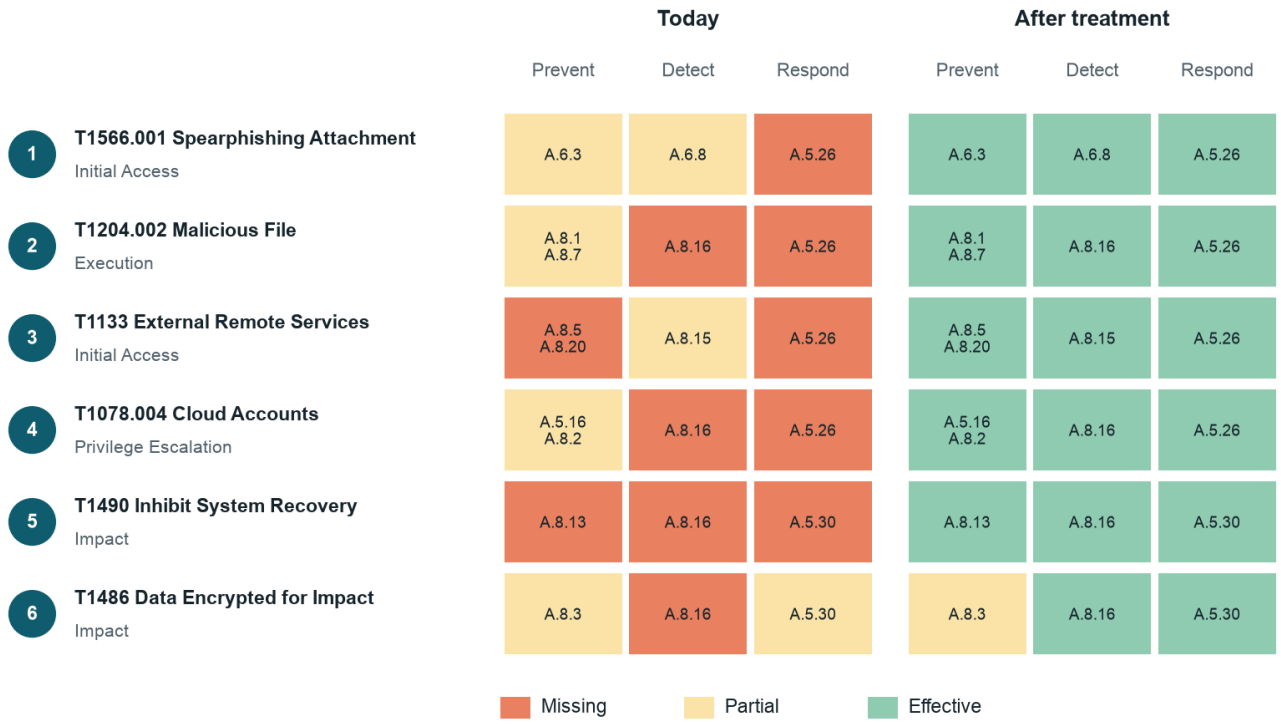


Figure 4: Ransomware through phishing: control coverage at each step, today and after treatment. Cells show Annex A control IDs.

Step	ATT&CK technique	What happens at Orvanta
1	T1566.001 Spearphishing Attachment	Staff member receives a fake invoice attachment
2	T1204.002 Malicious File	Attachment runs on a laptop without EDR
3	T1133 External Remote Services	Stolen VPN profile opens the legacy path to database subnets
4	T1078.004 Cloud Accounts	Shared database and admin credentials give full rights
5	T1490 Inhibit System Recovery	Backups and snapshots in the same account are deleted
6	T1486 Data Encrypted for Impact	Databases and storage are encrypted

What this shows. The decisive control is backup isolation. Even if every earlier step succeeds, immutable backups in a separate account turn a business-ending event into a recoverable outage.

4.3 Insider data exfiltration (SCN-C)

An analyst who is about to leave uses normal access to collect customer data and takes it out through a personal cloud drive and a USB stick.

Threat actor: Departing employee with legitimate access | Linked risks: RSK-06, RSK-07, RSK-25, RSK-30

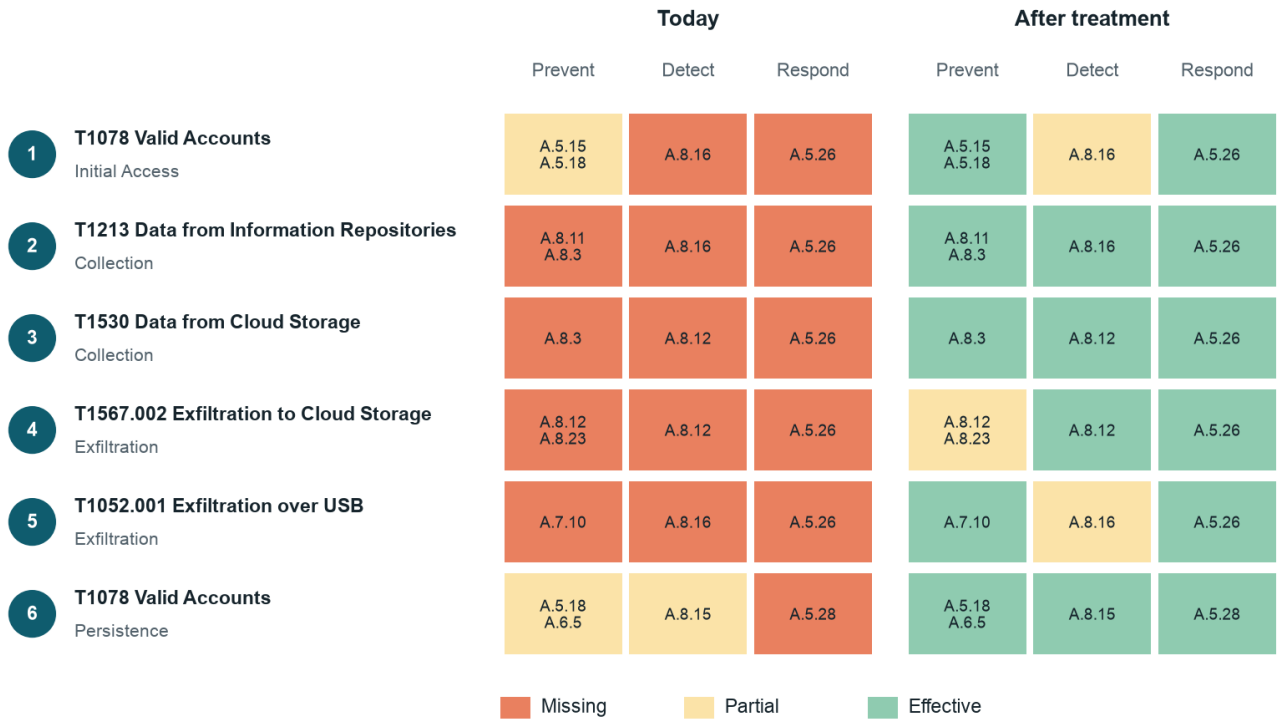


Figure 5: Insider data exfiltration: control coverage at each step, today and after treatment. Cells show Annex A control IDs.

Step	ATT&CK technique	What happens at Orvanta
1	T1078 Valid Accounts	Analyst uses their own valid account, with more access than the role needs
2	T1213 Data from Information Repositories	Unmasked customer data is queried in Metabase
3	T1530 Data from Cloud Storage	KYC files are downloaded from S3
4	T1567.002 Exfiltration to Cloud Storage	Files are uploaded to a personal cloud drive
5	T1052.001 Exfiltration over USB	Remaining files are copied to a USB stick
6	T1078 Valid Accounts	Access is still valid after the last working day

What this shows. Prevention can only go so far against a person with legitimate access, so this scenario depends on masking to limit what can be taken and on detection to notice it. It keeps the highest residual risk of the three.

5 Risk treatment plan

27 risks are mitigated, 1 is avoided by retiring legacy services, and 2 are accepted: one within appetite and one by formal record. Every action links to the certification roadmap, so there is one plan, not two.

ID	Action	Owner	Due	Status	Risks
TRT-01	Remove shared admin accounts and move to just-in-time privileged access with monthly review	Rashad Guliyev	30 Apr 2027	In progress	2
TRT-02	Replace long-lived AWS keys in repositories with short-lived OIDC roles	Rashad Guliyev	30 Apr 2027	In progress	1
TRT-03	Issue phishing-resistant security keys to admins and block unmanaged devices in Okta	Farid Ismayilov	31 Mar 2027	In progress	3
TRT-04	Enroll all 131 laptops in Jamf with disk encryption, EDR and remote wipe	Farid Ismayilov	31 Mar 2027	In progress	4
TRT-05	Run role-based awareness training and quarterly phishing simulations	Nino Beridze	31 May 2027	Planned	2
TRT-06	Enforce MFA on Metabase and Jenkins, and replace OpenVPN with identity-aware access	Farid Ismayilov	31 Mar 2027	In progress	2
TRT-07	Move backups to an isolated, immutable account and test restores every quarter	Rashad Guliyev	30 Apr 2027	In progress	2
TRT-08	Centralize logs, deploy a SIEM with ATT&CK-mapped detections and start daily triage	Nino Beridze	30 Jun 2027	Planned	1
TRT-09	Automate deprovisioning within 24 hours and run quarterly access reviews	Farid Ismayilov	31 Mar 2027	In progress	1
TRT-10	Mask personal data by default in Metabase, Orbit and non-production, and restrict production data access by role	Tomas Butkus	31 May 2027	Planned	4
TRT-11	Add Workspace DLP rules and alerts on bulk exports and downloads	Nino Beridze	31 May 2027	Planned	2
TRT-12	Keep ticket redaction on, give agents card-handling guidance and search tickets monthly	Mantas Žukas	31 Mar 2027	In progress	2
TRT-13	Enforce the CI deployment path with a second approver and a logged emergency route	Tural Mammadli	30 Apr 2027	In progress	1
TRT-14	Generate SBOMs, add SAST and secret scanning to every pipeline and retire Jenkins	Tural Mammadli	30 Apr 2027	In progress	2
TRT-15	Adopt vulnerability SLAs and retire the legacy AWS account	Rashad Guliyev	30 Apr 2027	In progress	1
TRT-16	Launch third-party risk management: tier 20 vendors, assess Tier 1 and update contract clauses	Eglė Norvilaitė	30 Jun 2027	Planned	4
TRT-17	Complete the BIA and continuity plan, including regional failure and supplier exit options	Ieva Petrauskaitė	31 May 2027	Planned	3
TRT-18	Require dual approval for payout files, rotate the SFTP key and verify file integrity	Indrė Sabaliauskaitė	30 Apr 2027	Planned	1
TRT-19	Approve the incident plan, two playbooks and a notification matrix, then run a tabletop exercise	Nino Beridze	31 May 2027	Planned	2
TRT-20	Complete the transfer impact assessment for Baku and apply its safeguards	Karolis Vaitkus	31 May 2027	Planned	1
TRT-21	Add SDLC security gates, threat modeling for payment changes and DAST in staging	Tural Mammadli	30 Apr 2027	In progress	1
TRT-22	Create a single asset register with owners and classification	Farid Ismayilov	31 Mar 2027	In progress	1
TRT-23	Hire a third security specialist, publish the RACI and move the CISO line to the CEO	Ugnė Baltrūnaitė	31 Mar 2027	In progress	2
TRT-24	Run the ISMS program to plan: KPIs, internal audit, management review and corrective actions	Nino Beridze	31 Aug 2027	In progress	1
TRT-25	Extend the obligations list into a legal register and map DORA duties to owners	Eglė Norvilaitė	30 Jun 2027	Planned	1
TRT-26	Review cyber insurance cover for ransomware and business interruption	Marius Stankus	31 Mar 2027	Planned	1

5.1 Accepted risk

RSK-16 (AWS region outage stops payments) stays at score 10 (High) after treatment. The CEO accepted it on 12 February 2027 until 31 December 2027, under record RA-01. A second live region would mean re-engineering the ledger, payment core and bank connection. At Orvanta's current scale that work would displace roadmap actions that reduce far more likely risks. Multi-AZ already protects against single data-center failure, which is the common case.

5.2 What treatment does not fix

- **Insider misuse.** A person with legitimate access can still take data. Masking limits the amount and detection shortens the time, but the risk stays Medium.
- **Supplier breaches.** Assessment and contracts improve assurance, but Orvanta cannot control a vendor's environment.
- **Design ratings.** Target scores assume controls work as designed. They stay provisional until the internal audit in July 2027 tests them.

5.3 Next steps

The selected controls feed the Statement of Applicability (Project 4) and the policy set (Project 3). Supplier risks drive the third-party program (Project 6), and scenarios SCN-A and SCN-B become incident playbooks (Project 7). This report is a point-in-time view, and it is not legal advice.

6 Appendix: risk register summary

Scores are likelihood x impact. The workbook holds full statements, assets, existing controls and Annex A controls for each risk.

ID	Risk	Owner	Threat and ATT&CK technique	Inherent	Today	Target	Option	Actions
RSK-01	Cloud administrator takeover	Rashad Guliyev	THR-03: T1552.001 Credentials In Files; T1078.004 Cloud Accounts	25	20	8	Mitigate	TRT-01, TRT-02
RSK-02	Credential phishing of engineers	Nino Beridze	THR-01: T1566 Phishing	20	16	6	Mitigate	TRT-03, TRT-04, TRT-05
RSK-03	Password attacks on tools outside Okta	Farid Ismayilov	THR-02: T1110.004 Credential Stuffing	20	16	4	Mitigate	TRT-06
RSK-04	Ransomware destroys production data and backups	Rashad Guliyev	THR-05: T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery	20	15	6	Mitigate	TRT-07, TRT-04, TRT-26
RSK-05	Intrusion goes undetected	Nino Beridze	THR-11: No technique needed	25	20	6	Mitigate	TRT-08
RSK-06	Former staff retain access	Farid Ismayilov	THR-15: T1078 Valid Accounts	16	9	3	Mitigate	TRT-09
RSK-07	Insider exfiltrates customer data	Karolis Vaitkus	THR-06: T1213 Data from Information Repositories; T1567.002 Exfiltration to Cloud Storage; T1052.001 Exfiltration over USB	20	15	8	Mitigate	TRT-10, TRT-11
RSK-08	Card data exposed in support tickets	Mantas Žukas	THR-02: T1110.004 Credential Stuffing	16	6	3	Mitigate	TRT-12
RSK-09	Unreviewed or malicious change reaches production	Tural Mammadli	THR-09: T1565.001 Stored Data Manipulation; T1657 Financial Theft	25	15	8	Mitigate	TRT-13
RSK-10	Compromised dependency or build pipeline	Tural Mammadli	THR-07: T1195.001 Compromise Software Dependencies and Development Tools	20	15	8	Mitigate	TRT-14
RSK-11	Exploitation of legacy internet-facing services	Rashad Guliyev	THR-04: T1190 Exploit Public-Facing Application; T1133 External Remote Services	20	16	4	Avoid	TRT-06, TRT-14, TRT-15
RSK-12	Breach at the KYC provider exposes identity documents	Eglė Norvilaitė	THR-08: T1199 Trusted Relationship	15	15	8	Mitigate	TRT-16
RSK-13	Card processor outage or failure	Emin Hasanov	THR-18: Not applicable	15	15	8	Mitigate	TRT-16, TRT-17
RSK-14	Support provider misuse or compromise	Mantas Žukas	THR-08: T1199 Trusted Relationship	16	12	6	Mitigate	TRT-16, TRT-12
RSK-15	Payment file tampering on the bank connection	Indrė Sabaliauskaitė	THR-09: T1565.001 Stored Data Manipulation; T1657 Financial Theft	15	10	5	Mitigate	TRT-18
RSK-16	AWS region outage stops payments	Rashad Guliyev	THR-16: Not applicable	10	10	10	Accept	TRT-17

ID	Risk	Owner	Threat and ATT&CK technique	Inherent	Today	Target	Option	Actions
RSK-17	Restore fails after data loss	Rashad Guliyev	THR-17: Not applicable	20	10	4	Mitigate	TRT-07, TRT-17
RSK-18	Incident mishandled and reporting duties missed	Nino Beridze	THR-17: Not applicable	20	16	6	Mitigate	TRT-19
RSK-19	Unmanaged laptop lost or stolen	Farid Ismayilov	THR-19: Not applicable	12	12	4	Mitigate	TRT-04
RSK-20	Personal data accessed from Baku without transfer safeguards	Karolis Vaitkus	THR-20: Not applicable	16	16	6	Mitigate	TRT-20, TRT-10
RSK-21	DDoS against the Merchant Payment API	Leyla Karimova	THR-12: T1498 Network Denial of Service	16	6	6	Accept	-
RSK-22	Session theft from an unmanaged device	Farid Ismayilov	THR-13: T1539 Steal Web Session Cookie	16	16	6	Mitigate	TRT-03, TRT-04
RSK-23	MFA fatigue attack on staff	Farid Ismayilov	THR-14: T1621 Multi-Factor Authentication Request Generation	12	12	4	Mitigate	TRT-03, TRT-05
RSK-24	API logic flaw enables payment fraud	Leyla Karimova	THR-04: T1190 Exploit Public-Facing Application; T1133 External Remote Services	20	15	8	Mitigate	TRT-21
RSK-25	Live personal data in test environments	Tomas Butkus	THR-17: Not applicable	12	9	3	Mitigate	TRT-10
RSK-26	Unowned assets left unprotected	Farid Ismayilov	THR-17: Not applicable	12	12	4	Mitigate	TRT-22
RSK-27	Key-person dependency in the security team	Ugnė Baltrūnaitė	THR-21: Not applicable	12	12	6	Mitigate	TRT-23
RSK-28	Certification missed and enterprise revenue lost	Ugnė Baltrūnaitė	THR-20: Not applicable	20	15	5	Mitigate	TRT-24, TRT-23
RSK-29	DORA ICT risk duties not met	Eglė Norvilaitė	THR-20: Not applicable	16	16	6	Mitigate	TRT-16, TRT-19, TRT-25
RSK-30	Bulk data theft from cloud storage	Rashad Guliyev	THR-10: T1530 Data from Cloud Storage	20	15	8	Mitigate	TRT-01, TRT-10, TRT-11